

M57.biz

Exfiltración de documentos corporativos

Análisis forense con Autopsy · Reconstrucción del ataque · Identificación del método de exfiltración

Exfiltración email

Spear Phishing

Windows XP

Autopsy 4.x

Herramienta: Autopsy 4.x · Imagen: nps-2008-jean.E01 · digitalcorpora.org

¿Qué pasó en M57.biz?

M57.biz es una startup de catálogo de arte corporal. A las pocas semanas de su fundación, una hoja de cálculo confidencial con nombres, salarios y números de seguridad social de todos los empleados apareció publicada en el foro del competidor.



Jean Jones

CFO • propietaria del portátil

Envió el archivo creyendo que lo pedía Alison



Alison Smith

Presidenta de M57.biz

Niega haber pedido o recibido el archivo



tuckgorge

Identidad desconocida — externo

tuckgorge@gmail.com — receptor del
archivo

¿Qué tiene que responder el investigador?

01 Localizar el archivo m57biz.xls en el disco y documentar sus metadatos (timestamps de creación y acceso).

02 Determinar cómo y cuándo fue enviado el archivo fuera de la empresa.

03 Identificar a quién llegó realmente el archivo y por qué canal — análisis de cabeceras de email.

04 Establecer si Jean Jones fue víctima de un ataque de spear phishing o actuó con intención criminal.

NOTA LEGAL

Ejercicio sobre imagen forense de libre uso de Digital Corpora. Datos ficticios. Solo en entornos de laboratorio autorizados.

Preparar Autopsy antes de empezar

1 — Descargar la imagen forense

```
# URL de descarga (Digital Corpora):  
→ https://digitalcorpora.org/corpora/scenarios/m57-jean/  
→ nps-2008-jean.E01 (~1.5 GB)  
→ nps-2008-jean.E02 (~1.5 GB)  
# Guardar ambos en la misma carpeta
```

2 — Crear caso en Autopsy

```
New Case → M57_Jean_Investigation  
Add Data Source → Disk Image  
→ Seleccionar nps-2008-jean.E01  
→ Autopsy detecta el .E02 solo  
Ingest Modules → activar los marcados
```

Ingest Modules críticos para este caso:

Recent Activity

Run Keys · historial web ·
USB

Windows Registry

Usuarios · software instalado

Email Parser

CRÍTICO — emails
PST/MBOX

File Type Identification

Clasifica por contenido real

Keyword Search

Buscar nombres y emails

Responder de forma autónoma

Explora Autopsy de forma independiente y anota dónde encontraste cada evidencia.

P1 Sistema y usuario

¿Qué sistema operativo tiene el portátil de Jean? ¿Cuántas cuentas de usuario existen?

Dónde buscar: OS Accounts · Windows Registry

P2 El archivo exfiltrado

¿Puedes localizar m57biz.xls? ¿Cuándo fue creado y cuándo fue accedido por última vez?

Dónde buscar: Keyword Search → 'm57biz' · Data Sources → C: → Documents and Settings

P3 El cliente de email

¿Qué programa usaba Jean para el correo? ¿Dónde están los emails almacenados en disco?

Dónde buscar: Data Sources → Application Data · Data Artifacts → Email Messages

Continúa la investigación

P4 El email sospechoso

¿Encuentras algún email con el archivo adjunto? ¿A qué direcciones fue enviado realmente?

Dónde buscar: Data Artifacts → Email Messages · Keyword Search → 'tuckgorge'

P5 La línea de tiempo

¿Cuánto tiempo pasó entre que se creó el archivo y se envió por email? ¿Qué te dice ese dato?

Dónde buscar: Timeline (menú superior) · File Metadata del archivo

P6 Conclusión

Con toda la evidencia: ¿fue Jean víctima de phishing o actuó con intención criminal? Justifica con evidencia.

Dónde buscar: Cabeceras del email · Timestamps · Destinatarios reales

CASO M57-JEAN - PARTE 04

Guía paso a paso

Soluciones

04

Paso 01 + 02 — Sistema y archivo

01 — Identificar SO y usuario

```
# Árbol izquierdo de Autopsy:  
→ OS Accounts  
→ Data Sources → C: → Windows  
  → System32 → config → SAM  
# Resultado esperado:  
→ Usuario: jean  
→ Sistema: Windows XP
```

02 — Localizar m57biz.xls

```
# Keyword Search (arriba a la derecha):  
→ Buscar: m57biz  
→ Buscar: m57plan  
# O navegar:  
→ C:\Documents and Settings\jean  
  \My Documents  
# Clic en archivo → File Metadata
```

LO QUE DEBES ENCONTRAR

m57biz.xls · Created Time: 2008-07-20 02:28:03 · Access Time: ~02:28:45 (momento del envío)

Paso 03 — Encontrar los emails

Después de que terminen los Ingest Modules:

```
# Ir a:  
→ Data Artifacts → Email Messages  
  
# Si no aparece, buscar el PST manualmente:  
→ C:\Documents and Settings\jean\Local Settings\  
Application Data\Microsoft\Outlook\  
  
# Keyword Search para encontrar emails relevantes:  
→ Buscar: tuckgorge  
→ Buscar: m57biz  
→ Buscar: @gmail.com
```

PREGUNTA CLAVE

¿Qué cliente de email usaba Jean — Outlook, Thunderbird o webmail? La respuesta cambia dónde están los mensajes. Mira qué aplicaciones hay instaladas en Data Sources → Program Files.

Paso 04 — La cadena de emails

Secuencia de emails que reconstruye el ataque:

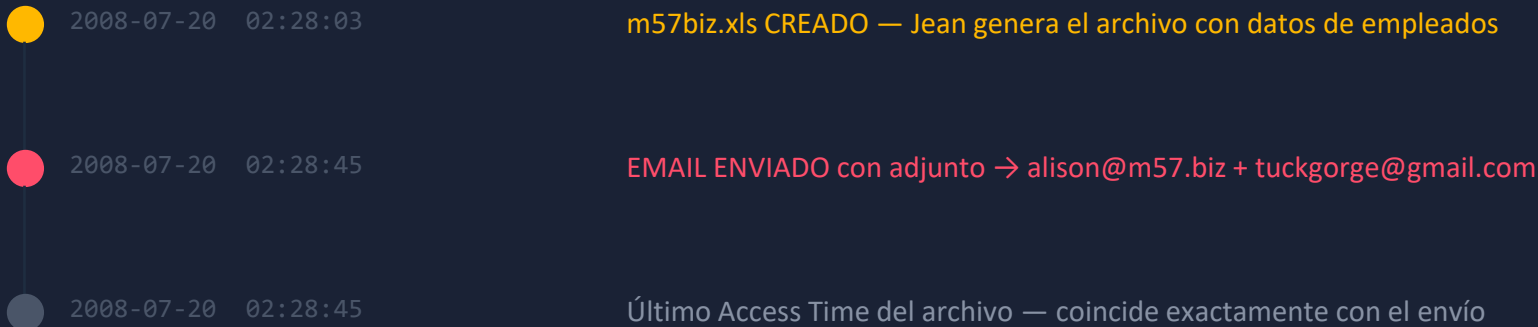
```
# Email 1 – petición inicial:  
→ De: alison@m57.biz (o alguien suplantándola)  
→ Para: jean@m57.biz · pide la hoja de cálculo  
  
# Email 2 – Jean pregunta:  
→ Jean nota algo raro – pregunta si usar alex@ o alison@  
→ Indica que Jean tuvo dudas sobre la identidad  
  
! Email 3 – LA EXFILTRACIÓN:  
→ De: jean@m57.biz  
! Para: alison@m57.biz + tuckgorge@gmail.com  
! Adjunto: m57biz.xls ← EL ARCHIVO ROBADO  
! Jean envía a DOS destinatarios – uno externo desconocido
```

CABECERAS – LO MÁS IMPORTANTE

Clic en el email → panel inferior → pestaña Text. Buscar campo Reply-To. Si es diferente al campo From, el atacante configuró que las respuestas fuesen a su cuenta, no a la de Alison. Esa es la firma técnica del spear phishing.

Paso 05 — Línea de tiempo

```
# Autopsy — menú superior:  
→ Timeline → zoom al 20 de julio de 2008  
# Filtrar por tipo:  
→ File System · Web Activity · Email
```



EL DATO CLAVE — 42 SEGUNDOS

Entre crear el archivo y enviarlo pasaron solo 42 segundos. Jean no lo abrió para revisarlo — lo creó y lo envió casi instantáneamente. ¿Respondía una petición urgente o sabía exactamente lo que hacía?

Paso 06 — ¿Víctima o cómplice?

Apoya que Jean fue VÍCTIMA

- ✓ El email de petición parecía legítimo
- ✓ Jean preguntó sobre la dirección → tuvo dudas
- ✓ No hay evidencia de que supiera quién era tuckgorge
- ✓ El Reply-To estaba oculto en cabeceras técnicas

Genera SOSPECHA sobre Jean

- ! Envió a DOS destinatarios — uno externo
- ! Solo 42 segundos entre crear y enviar
- ! Alison niega haber pedido el archivo
- ! El contenido incluía SSN — dato muy sensible

CONCLUSIÓN ACADÉMICA

Jean fue víctima de spear phishing. El atacante (tuckgorge) simuló la cuenta de Alison para engañarla. Jean actuó de buena fe pero sin verificar el destinatario real. El caso es deliberadamente ambiguo — exactamente como en investigaciones reales.

Paso 07 — Generar el reporte forense

Antes de generar el reporte — marcar artefactos clave:

Clic derecho sobre cada artefacto → Add Tag → Notable Item:

- Archivo m57biz.xls
- Email con adjunto a tuckgorge@gmail.com
- Timestamps del archivo (Created / Access Time)
- Cabeceras del email (si Reply-To ≠ From)

Generar el reporte:

- Tools → Generate Report
- Report Type: HTML Report → Next
- Activar: All Tagged Results → Next → Finish
- El reporte se guarda en la carpeta del caso

El reporte debe responder:

1. ¿Cuándo se creó el archivo y desde dónde fue enviado?
2. ¿A qué dirección llegó realmente la exfiltración?
3. ¿Hay evidencia de intención criminal por parte de Jean?

Mapa de evidencias del caso

Evidencia	Dónde en Autopsy	Qué muestra
m57biz.xls	Keyword Search → m57biz	Archivo exfiltrado con timestamps
Created Time	File Metadata del archivo	2008-07-20 · 02:28:03
Email exfiltración	Data Artifacts → Email Messages	Destinatarios: Alison + tuckgorge@gmail
Reply-To sospechoso	Email → pestaña Text → cabeceras	Diferente al campo From = phishing
42 segundos	Timeline → 2008-07-20	Crear → enviar casi instantáneo
Cuenta de usuario	OS Accounts	jean / Windows XP

NOTA FINAL – MARCO LEGAL

Análisis sobre sistemas reales sin autorización = delito Art. 197 bis CP (hasta 2 años). Solo sobre la imagen de práctica proporcionada en clase.

El forense busca lo que el atacante no pudo borrar

Archivo m57biz.xls

Localizado · timestamps
reales

Email exfiltración

Jean → alison +
tuckgorge@gmail

42 segundos

Crear → enviar · dato clave

Conclusión

Spear phishing · Jean como
víctima